

可证明安全的后量子两方口令认证密钥协商协议^{*}

倪亮¹, 张亚伟¹, 王念平², 周恒昇¹, 刘笑颜¹, 谷兵珂¹

(1. 中原工学院 计算机学院, 郑州 450007; 2. 信息工程大学 密码工程学院, 郑州 450001)

摘要: 口令认证密钥协商可以在客户机和服务器之间建立安全的远程通信,且可以将一个低熵口令放大为一个高熵的会话密钥。然而,随着量子计算技术的快速发展,基于大数分解和离散对数等经典数学难题的PAKA协议面临着严峻的安全挑战。因此,为了构建一个高效安全的后量子PAKA协议,依据改进的Bellare-Pointcheval-Rogaway(BPR)模型,提出了一个基于格的匿名两方PAKA协议,并且使用给出严格的形式化安全证明。性能分析结果表明,该方案与相关的PAKA协议相比,在安全性和执行效率等方面有一定优势,更适用于资源受限的物联网(Internet of Things, IoT)智能移动设备。

关键词: 口令认证密钥协商; 基于格的密码; 环上带误差学习; 可证明安全; 抗离线字典攻击

中图分类号: TP309

文献标志码: A

文章编号: 1001-3695(2023)04-040-1208-06

doi:10.19734/j.issn.1001-3695.2022.07.0377

Provably secure post-quantum two-party password authenticated key agreement protocol

Ni Liang¹, Zhang Yawei¹, Wang Nianping², Zhou Hengsheng¹, Liu Xiaoyan¹, Gu Bingke¹

(1. School of Computer Science, Zhongyuan University of Technology, Zhengzhou 450007, China; 2. College of Cryptography Engineering, Information Engineering University, Zhengzhou 450001, China)

Abstract: Password authentication key agreement can not only establish secure remote communication between client and server, but also amplify a low-entropy password into a high-entropy session key. However, with the rapid development of quantum computing technology, PAKA protocol based on classical mathematical problems such as large number decomposition and discrete logarithm is facing serious security challenges. Thus, in order to construct an efficient and secure post-quantum PAKA protocol, this paper proposed a post-quantum lattice-based anonymous two-party PAKA protocol based on the improved BPR model and gave a strict formal security proof. The performance analysis results show that compared with the related PAKA protocol, the proposed protocol has some advantages in security and execution efficiency. So it is more suitable for resource-constrained Internet of Things smart mobile devices.

Key words: password authenticated key agreement (PAKA); lattice-based cryptography; ring learning with error; provable security; resistance to offline dictionary attacks

0 引言

口令便于人类记忆且避免了使用公钥基础设施(public key infrastructure, PKI),也无须使用硬件存储。因此,口令成为了一种普遍的认证方法^[1,2]。口令认证密钥协商协议(password authenticated key agreement, PAKA)是认证密钥协商协议的一个重要研究分支,它支持通信双方(如服务器和持有智能设备的用户)在不安全的公开网络上使用简单的低熵口令协商出高熵会话密钥,与其他认证方式相比效率较高。但是随着量子计算机的快速发展,基于传统数学难题的加密算法无法保障安全,越来越多的学者和学术团体开始研究抗量子算法,基于格的算法凭借其简单、高效和并行性成为后量子密码算法的研究热点。但是早期的基于格的方案着重于密钥协商而不是互相认证,如文献[3]。直到2017年,Ding等人^[4]提出了一个基于理想格的PAKA协议,不过该方案的通信开销太大,实际执行难度较大。Gao等人^[5]对Ding方案^[4]进行了优化,并且

给出了一种适合于数论变换(number theoretic transforms, NTT)算法的参数集,但该参数集没有考虑通信负担。此外Feng等人^[6]引入了一种用于移动设备的匿名密钥协商协议。在随机预言模型(random oracle model, ROM)中给出了安全性证明,Rana等人^[7]提出了一个基于环上带误差学习问题(ring learning with error, RLWE)的PAKA协议,并与其他方案进行了比较。在文献[6,7]提出的两方PAKA协议的启发下,本文对文献[7]基于随机预言模型PAKA协议的改进后,构造了一个基于RLWE的2轮匿名PAKA协议,并且在改进的Bellare-Pointcheval-Rogaway(BPR)模型^[8]中进行了严格的安全证明,本文改进如下:a)使用累积分布函数齐普夫法则模型(cumulative distribution function Zipf's law, CDF-Zipf)^[9]模拟敌手的在线攻击能力;b)为了简化证明,本文提出带误差配对问题(pairing with error, PWE)。将安全证明降低为可抗在线字典攻击的证明,并证明所提方案满足前向安全性,且与相关方案相比执行效率较高,更适用于资源受限的物联网设备。

收稿日期: 2022-07-03; **修回日期:** 2022-09-01 **基金项目:** 河南省科技攻关计划资助项目(232102210134, 182102210130); 国家留学基金资助项目(201908410281); 国家自然科学基金资助项目(61672031); 河南省高等学校重点科研项目(21A520053)

作者简介: 倪亮(1975-),男,辽宁葫芦岛人,副教授,博士,主要研究方向为网络安全和密码学(niliang402@zut.edu.cn); 张亚伟(1997-),男,河南兰考人,硕士研究生,主要研究方向为网络安全与密码学; 王念平(1973-),男,教授,博士,主要研究方向为信息安全和密码学; 周恒昇(1997-),男,硕士研究生,主要研究方向为网络安全与密码学; 刘笑颜(1998-),女,硕士研究生,主要研究方向为网络安全与密码学; 谷兵珂(1996-),男,硕士研究生,主要研究方向为网络安全与密码学。

1 预备知识

在介绍预备知识之前,先介绍相关的符号说明,如表1所示。

表1 相关符号说明
Tab. 1 Description of relevant symbols

参数	含义	参数	含义
λ	安全参数	$ x $	x 的绝对值
q	RLWE 问题的模数	pw	口令
$\leftarrow$	均匀随机取样操作	D	口令空间
$\ x\ $	x 的取模操作	$\perp$	非法标识
$ $	串连接	χ_β	格上离散高斯分布

1.1 基于格的难题假设

本节主要介绍格的概念、RLWE 假设和本文方案用到的数学知识。

格的定义:设矩阵 $B = b_1, b_2, b_3, \dots, b_n \in \mathbb{R}^{m \times n}$ 的列向量线性无关,定义格 L 为

$$L = \sum_{i=1}^n b_i x_i$$

其中: $x \in Z, i = 1, 2, 3, \dots, n$ 。 B 是格 L 的基,维数是 m 。

基于格的加密算法的困难性需要在平均情况下的困难性。1996年,Ajtai^[10]证明了基于格的难题可以从最坏情况到平均情况归约,使得基于格的加密算法具有了可证明安全的性质。在基于格的困难假设中,有几种重要的平均情况困难问题,如最小整数解问题(small integer solutions, SIS)、LWE、RLWE。在一定条件下,这些问题可以归约到最短线性无关向量问题(shortest independent vector problem, SIVP)、近似最近向量问题(approximate closest vector problem, ACVP)等格上的困难问题(即求解这些问题并不比求解格上困难问题容易)。RLWE 与 LWE 问题很类似,只不过在 RLWE 使用多项式代替 LWE 中的矩阵。基于 RLWE 的方案提高了计算效率,减小了通信开销。

1.1.1 RLWE 假设

首先设 q 是一个大于2的奇素数, R 和 Z 依次为实数集和整数集, $Z[X]$ 和 $Z_q[X]$ 分别为在 Z 和 Z_q 上的多项式环的子集, $R_1 = Z[X]/X^{n+1}$ 为环上整数多项式 $Z[X]$ 对 X^{n+1} 取模运算, $R_q = Z_q[X]/X^{n+1}$ 表示 $Z_q[X]$ 对 X^{n+1} 取模运算和环上多项式 $Z_q[X]$ 的系数对 q 取模运算。基于格的加密方案的安全性依赖于 n 维欧氏空间 R^n 中的难题^[11]。

RLWE 问题:给定 $A, s, y \leftarrow R_q$, 噪声 $e \leftarrow \chi_\beta$, A, e 相互独立,记 $b_i = A_i s + e_i$ 。

定义1 搜索版 RLWE 问题(S-RLWE)^[12]。给定多组 (A_i, b_i) , 任意敌手在多项式时间内解出密钥 s 是困难的。

定义2 判定版 RLWE (D-RLWE)^[12]。任意多项式时间敌手区分 (A, b) 和均匀随机选取的样本 (A', b') 是困难的。

定义3 带误差配对问题(pairing with error, PWE)^[4]。假设一个概率性多项式敌手 A 持有 (A, y, z) , 其中 $A, y \leftarrow R_q, z = As + 2e$, 记 $F(y, s) = \text{REC}(ys, \text{Cha}(ys))$, 任意敌手在多项式时间解出 F 的值是困难的。

定义4 判定版 PWE 问题 D-PWE^[4]。记 $z = As + 2e, z^1 = y \times s + 2e_1$, 定敌手 A, y , 当 s, e, e_1 未知, 任意概率多项式时间(probabilistic polynomial-time, PPT)敌手解出 z 和 z^1 或者是区分 (z, z^1) 和 $(Z, Z^1) \leftarrow R_q \times R_q$ 是困难的。

下面介绍 PWE 问题可以归约为 RLWE 问题。很明显,若 PWE 问题是困难的,则 DPWE 问题也是困难的。

引理1 若 DPWE 问题是困难的,则 RLWE 问题也是困难的^[13]。

证明 假设 RLWE 问题是难以解决的,但是存在 PPT 算法 Q 以不可忽略的优势解决 DPWE 问题,设有算法 Q^1 可以调用 Q 算法,则有:

a) 输入 (A, y, z) 。

b) 调用算法 Q 使用 (A, y, z) 解决 DPWE 问题,如果 Q 输出1,那么 Q^1 也输出1,表示敌手 A 可以利用某些 $s, e, e_1 \leftarrow R_q$ 计算出 z, z^1 ,即表示敌手 A 可以解决 Search-RLWE 问题。如果 Q 输出0,那么 Q^1 也输出0,表示敌手 A 可以区分 (z, z^1) 和 $R_q \times R_q$ 上均匀随机的样本,即敌手可以解决 D-RLWE 问题。

若 Q 解决 DPWE 问题具有不可忽略的优势,那么 Q^1 解决 RLWE 问题也具有不可忽略的优势,这与 RLWE 问题难以解决的假设相反。所以得出如果 DPWE 问题是困难的,那么 RLWE 问题也是困难的。继而得出 PWE 问题可以归约为 RLWE 问题,即 $\text{PWE} \xrightarrow{\text{引理1}} \text{DPWE} \rightarrow \text{RLWE}$ 。

1.1.2 数学背景

下面介绍本方案用到的数学知识,设任一多项式 $c = c_0^2 + c_1^2 + c_2^2 + \dots + c_{n-1}^2 \in \mathbb{R}$, 定义范式 $\|c\| = \sqrt{c_0^2 + c_1^2 + c_2^2 + \dots + c_{n-1}^2}$, 定义格 L 上的范式为 $c_\infty = \max\{c_0, c_1, c_2, \dots, c_{n-1}\}$ 。

引理2 设 $c, d \leftarrow R_q$, 下列不等式成立^[7]:

$$\|c \cdot d\| \leq \sqrt{n} \cdot \|c\| \cdot \|d\| \quad (1)$$

$$\|c \cdot d\|_\infty \leq n \cdot \|c\| \cdot \|d\| \quad (2)$$

在文献[4]中,提出了一种通用且方便的误差协调机制,称为 DING 式误差协调,并且以其简单高效的的优势在构造密钥协商协议广泛应用。因此本方案采用 DING 式消除误差。下面简单介绍 DING 式误差协调机制。设 E 是 $Z_q = \{- (q-1)/2, \dots, (q-1)/2\}$ 的子集, $E = \{- \lfloor (q-1)/4 \rfloor, \dots, \lfloor (q-1)/4 \rfloor\}$, $\forall c \in Z_q$ 的补集特征函数^[7] Cha 定义为

$$\text{Cha}(c) = \begin{cases} 0 & c \in E \\ 1 & c \notin E \end{cases} \quad (3)$$

因此,有 $c + \text{Cha}(q-1) \bmod q \in E$, 其中 $c \leftarrow R_q$ 。提取模块函数 REC 定义为如下的一个映射^[7], 有式(4)成立。

$$\text{REC}: R_q \times \{0, 1\} \rightarrow \{0, 1\};$$

$$\text{REC}(a, b) = (a + b \cdot \frac{q-1}{2}) \bmod q \bmod 2 \quad (4)$$

其中: $a \in R_q, b = \text{Cha}(a)$ 。

引理3 设 q 是奇素数, $c \in R_q$, 若 $c = d + 2e$, 其中 $|e| < q/8$, 则式(5)成立。

$$\text{REC}(c, b) = \text{REC}(d, b) \quad (5)$$

证明 因为 $d + b \times (q-1)/2 \bmod q = c + b \times (q-1)/2 + 2e \bmod q$, 又因 $c + b \times (q-1)/2 \bmod q \in E$, 故 $- \lfloor (q-1)/4 \rfloor \leq c + b \times (q-1)/2 \leq \lfloor (q-1)/4 \rfloor$, $- \lfloor (q-1)/2 \rfloor \leq c + b \times (q-1)/2 + 2e \bmod q \leq \lfloor (q-1)/2 \rfloor$, 即 $c + b \times (q-1)/2 + 2e = c + b \times (q-1)/2 + 2e \bmod q = d + b \times (q-1)/2 \bmod q$ 。所以 $\text{REC}(c, b) = \text{REC}(d, b)$ 。证毕。

REC 函数和 Cha 特征函数都可以应用到环 R_q 上, 因为 $c = c_0^2 + c_1^2 + c_2^2 + \dots + c_{n-1}^2 \in \mathbb{R}, d = (d_0, d_1, d_2, \dots, d_{n-1}) \in \{0, 1\}^n$, 故环 R_q 上的特征函数 Cha 定义为

$$\text{Cha}(c) = \{\text{Cha}(c_0), \text{Cha}(c_1), \text{Cha}(c_2), \dots, \text{Cha}(c_{n-1})\}$$

提取模块函数 REC 定义为

$$\text{REC} = \{\text{REC}(c_0, d_0), \text{REC}(c_1, d_1), \text{REC}(c_2, d_2), \dots, \text{REC}(c_{n-1}, d_{n-1})\}$$

1.2 格上离散高斯分布

基于格的加密方案的采样一般来自离散高斯分布或是均匀分布, 其中应用最为广泛的当属离散高斯分布。离散高斯分布采样的优势主要是可以减小密文的尺寸, 通过采样噪声恢复或是加密明文, 下面介绍格上离散高斯分布。

定义 5 格上高斯分布^[14]。已知格 $L \in \mathbb{R}^n$, 对于任意实数 $\beta > 0$, 存在随机变量 $x \in \mathbb{R}^n$, $\mathbb{R}^n$ 上以向量 $v \in \mathbb{R}^n$ 为中心, 平滑参数 β 的高斯函数定义为

$$\rho_{\beta,v}(x) = \exp(-\pi \frac{\|x-v\|^2}{\beta^2}) \quad (6)$$

高斯函数 $\rho_{\beta,v}(x)$ 的连续高斯分布定义为

$$D_{\beta,v}(x) = \frac{\rho_{\beta,v}(x)}{\beta^n} \quad (7)$$

其中: $\beta^n = \int_{x \in \mathbb{R}^n} \rho_{\beta,v}(x) dx$ 。

定义 6 格上离散高斯分布: 已知格 $L \in \mathbb{R}^n$, 对于任意实数 $\beta > 0$, 向量 $v \in \mathbb{R}^n$, 格 L 上的离散高斯分布定义为

$$D_{L,\beta,v}(x) = \frac{D_{\beta,v}(x)}{D_{\beta,v}(L)} = \frac{\rho_{\beta,v}(x)}{\rho_{\beta,v}(L)} \quad (8)$$

其中: $D_{\beta,v}(L) = \sum_{x \in L} D_{\beta,v}(x)$, $\rho_{\beta,v}(L) = \sum_{x \in L} \rho_{\beta,v}(x)$, 当正实数 β 足够大时, 分布 $D_{L,\beta,v}(x)$ 与 $D_{\beta,v}(L)$ 十分相似。若向量服从分布 $D_{L,\beta,v}$, 其均值十分逼近中心向量 v ; 若向量服从分布 $D_{\beta,v}(L)$, 其均值十分逼近中心向量 v , 并且有引理 4 成立。

引理 4 假设 $\beta = \omega \sqrt{\log n}$ 是 χ_β 的标准差, $c \leftarrow R_q$, 有式 (9) 成立^[6]。

$$\Pr_{c \leftarrow \chi_\beta}[\|c\| > \beta \sqrt{n}] \leq 2^{1-n} \quad (9)$$

1.3 Bellare-Pointcheval-Rogaway 安全模型

根据文献[8]中描述的 BPR 模型, 本文给出一种改进的 BPR 安全模型, 该模型更能模拟 PAKA 协议所面临的真实挑战。本节简短介绍安全模型。

1.3.1 通信模型

本文以一个用户 C 为例进行 PAKA 协议的研究。PAKA 协议的参与者包括一个用户 $C \in \text{client}$, 一个服务器 $S \in \text{server}$ 和 PPT 敌手 $A \in \text{ADV}$ 。用户 C 持有一个口令 pw , 服务器 S 存储与用户口令 pw 相关的哈希值 $r = H(pw)$ 。每个参与者都能与不同合作伙伴多次执行 PAKA 协议。因此, 本协议用 Π 模拟参与者的实例, 如用 Π_C^i 表示用户 C 的第 i 个实例, 用 Π_S^j 表示服务器 S 的第 j 个实例。每个实例都拥有一个状态参数 (pid , sid , sk , acc , $temp$) 且每个实例只能使用一次。 pid 表示协议参与者的身份标识, sid 表示当前会话的标识, sk 表示当前会话的密钥。 $temp$ 和 acc 都是 2 值变量, 当 $temp = 1$ 表示实例 Π_C^i 完成了发送和接收, 当 $acc = 1$, 表示实例 Π_C^i 被其他参与者成功接收。一个服务器 S 可以满足多个用户 C 的请求。

为了方便描述敌手模型, 下面介绍一下伙伴关系。

伙伴关系: 实例 Π_C^i 包含状态参数 (pid , sid , sk , acc , $temp$), 实例 Π_S^j 包含状态参数 (pid_1 , sid_1 , sk_1 , acc_1 , $temp_1$), 如果 $pid = S$, $pid_1 = C$, $sid = sid_1 \neq \perp$, $sk = sk_1$, 当满足上述条件, 称实例 Π_C^i 和 Π_S^j 为伙伴关系。

1.3.2 敌手模型

因为在 PAKA 协议执行过程中存在用户 C 和服务器 S 之间的通信, 所以本模型假设存在一个 PPT 敌手 $A \in \text{ADV}$ 可以通过拦截、窃听、延迟等手段完全控制用户 C 和服务器之间认证阶段的所有通信, 包括: a) 入侵某个用户 C 的认证服务器获得服务器内部的状态信息, 并且可以通过已经泄露的服务器向用户发送认证消息; b) 入侵某个用户 C 的智能设备获得智能设备内的内部状态, 通过该用户向其服务器发送认证消息。

BPR 模型通过预言查询机制模拟敌手 A 的攻击能力。敌手通过以下不同的预言查询对本协议实现不同攻击。

a) $\text{execute}(C, i, S, j)$: 该预言查询模拟敌手 A 离线字典口令攻击, 窃听实例 Π_C^i 、 Π_S^j 之间的通信, 根据本协议的定义将所得信息发送给敌手 A 。

b) send 预言查询模拟敌手 A 在线攻击, 敌手可以向实例 Π_C^i 、 Π_S^j 发送 send 预言查询。

c) $\text{send}(C, i, M)$: 该预言查询模拟敌手 A 主动攻击, 敌手 A 向实例 Π_C^i 发送消息 M , 根据本协议的定义将用户 C 对 M 的回答信息返回给敌手 A 。特别地, 当消息 M 为 $\text{send}(C, i, S, j)$ 时, 可以启动用户 C 和服务器 S 执行一次协议。

d) $\text{send}(S, j, M)$: 该预言查询模拟敌手 A 主动攻击, 敌手 A 向实例 Π_S^j 发送消息 M , 根据本协议的定义将服务器 S 对 M 的回答信息返回给敌手 A 。

e) $\text{reveal}(C, S, i)$ (其中 $S \in \text{pid}_1$): 该预言查询模拟临时会话密钥泄露攻击, 如果临时会话密钥遭到非法攻击导致泄露, 根据本协议的定义向敌手 A 返回会话密钥 sk 。

f) $\text{corrupt}(C)$: 该预言查询模拟用户 C 口令泄露, 向敌手 A 返回用户的口令 pw 。

g) $\text{corrupt}(S)$: 该预言查询模拟服务器 S 泄露, 向敌手返回 $H(pw)$ 。

为了方便描述 test 预言查询, 下面介绍会话密钥 sk 新鲜性的概念。

新鲜性: 设 $V = CUS$, 当实例 Π_C^i 和 Π_S^j 互为伙伴关系时, 如果敌手 A 未执行过: (a) $\text{reveal}(V, i)$ 预言查询; (b) 服务器 S 未发生泄露, 称会话密钥 sk 是新鲜的。

h) $\text{test}(V, i)$: 该预言查询不模拟任意 PPT 敌手 A 的真实攻击, 只用于定义协议的语义安全, 本预言查询表示, 随机选择一个比特 b 描述敌手攻击优势, 如果 $b = 1$, 实例向敌手 A 返回会话密钥 sk , 否则返回一个从字典空间 D 中选取的等长随机字符串。敌手只有一次 test 预言查询机会, 且只能对新鲜的 sk 执行。

正确性: 实例 Π_C^i 和 Π_S^j 互为伙伴关系, 如果 $sid = sid_1 \neq \perp$, $pid = S$, $pid_1 = C$, $sk = sk_1$, $acc = acc_1 = 1$, 称双方 PAKA 协议成立。

敌手优势: 口令认证密钥协议需要满足语义安全性, 即敌手 A 无法区分真实会话密钥 sk 和与 sk 等长的随机字符串, 当敌手 A 执行 test 预言查询后, 输出一个猜测比特 b_1 , 当 $b_1 = b$ 时, 称敌手 A 攻击成功协议 P 并记为事件 $\text{succ}(\lambda)$, 定义敌手优势 $\text{ADV}_A^P(\lambda)$ 为

$$\text{ADV}_A^P(\lambda) = |2\Pr(\text{succ}_A^P(\lambda)) - 1| \quad (10)$$

理论上, 敌手 A 攻击成功的概率上限是 $1/2 + \text{negl}(\lambda)$ ($\text{negl}(\lambda)$ 是可忽略函数), 此时敌手优势 $\text{ADV}_A^P(\lambda)$ 上限是 $\text{negl}(\lambda)$, 但是实际上用户使用的口令字典空间比较小, PPT 敌手 A 可以通过在线字典攻击攻击成功, 所以敌手 A 优势的上限必大于 $\text{negl}(\lambda)$ 。根据文献[14], 若口令服从均匀分布模型, 此时敌手的优势 $\text{ADV}_A^P(\lambda)$ 上限是 $N/\|D\| + \text{negl}(\lambda)$ (其中 N 为 PPT 敌手 A 在线攻击次数的上限), 但根据文献[9]可知, 服从均匀分布的传统 PAKA 协议大大低估了敌手的攻击能力, 目前是不够安全的。因此本方案假设口令服从 CDF-Zipf 模型, 采用 CDF-Zipf 的口令模型的敌手优势与真实敌手优势相差上限最多为 0.491%, 且与基于服从均匀分布的口令模型相比, 敌手 A 利用基于 CDF-Zipf 分布的口令猜测成功的概率至少会提升 2、3 倍。所以本文提出的 PAKA 协议的安全模型能真实地模拟 PAKA 协议面临的挑战。

2 基于 RLWE 的 PAKA 方案设计

2.1 初始阶段

服务器 S 通过以下算法生成密钥对 (y_s, s_s) 与系统参数 $\{A, n, q, \chi_\theta, H(\cdot)\}$ 。

a) 服务器 S 选取公共参数 $A \leftarrow R_q$ 和一个离散高斯分布 χ_θ 。

b) 服务器 S 选取两个整数 $n, q \leftarrow Z$ 且满足 $q \bmod 2n = 1$, 私

钥 s_s 和噪声 $e_1, s_s, e_1 \leftarrow \chi_\beta$, 然后计算服务器 S 的公钥 $y_s = As_s + 2e_1$ 得到密钥对 (y_s, s_s) 。

c) 服务器 S 选取哈希函数 $H(\cdot): \{0,1\}^* \rightarrow \{0,1\}^l$, 其中 l 为散列函数长度。

d) 服务器 S 公开系统参数 $\{A, n, q, \chi_\beta, y_s, H(\cdot), ID_s\}$, 保留私钥 s_s 。

2.2 注册阶段

本阶段在安全信道中执行, 保证用户 C 和服务器 S 之间的通信安全, 从而实现匿名性。

a) 用户 C 使用智能设备端输入身份信息 ID_c 和口令 pw , 计算 $G_u = H(ID_c || pw)$, 然后用户 C 向服务器 S 发送 G_u, ID_c 。

b) 服务器 S 检查 ID_c , 若 ID_c 正确, 然后计算 $G_1 = H(ID_c || s_s), G_2 = G_1 \oplus G_u$, 服务器 S 存储 G_1 , 向用户 C 发送 G_2 。

c) 用户 C 接收 G_2 , 然后计算 $G_1 = G_2 \oplus G_u$, 用户 C 存储 G_2, ID_s 。注册阶段如图1所示。

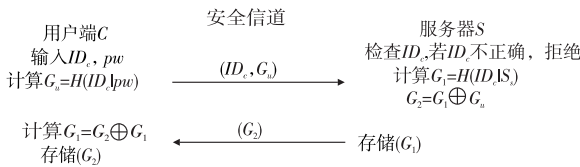


图1 注册阶段
Fig.1 Registration phase

2.3 认证阶段

本阶段在公开信道执行, 任意敌手都可以对用户 C 和服务器 S 之间的通信进行监听、拦截等攻击。认证阶段如图2所示。

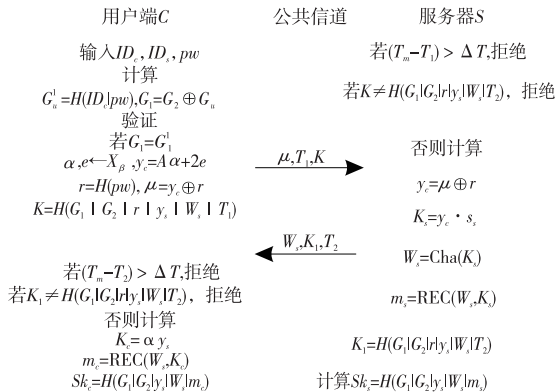


图2 认证阶段
Fig.2 Authenticated phase

a) 用户 C 使用智能设备先输入 ID_c 和口令 pw 登录, 计算 $G_u = H(ID_c || pw), G_1 = G_2 \oplus G_u$, 若 $G_1 = G_1'$ 成立, 表示用户登录成功, 然后用户 C 申请一个时间戳 T_1 , 挑选的私钥 α 和噪声 e , $\alpha, e \leftarrow \chi_\beta$ 。计算 $y_c = A\alpha + 2e, r = H(pw), \mu = y_c \oplus r$ 认证参数 $K = H(G_1 || G_2 || r || y_s || W_1 || T_1)$ 。用户 C 获得密钥对 (y_c, α) , 向服务器 S 发送参数 μ, T_1, K 。

b) 在服务器 S 接收 μ, T_1, K 后, 若 $T_m - T_1 > \Delta T$ (其中 T_m 表示 S 接收到消息的时间, ΔT 表示可接受的最大间隔时间) 或认证参数 $K \neq H(G_1 || G_2 || r || y_s || W_1 || T_1)$, 则拒绝, 否则服务器 S 申请一个时间戳 T_2 , 然后计算 $y_c = \mu \oplus r$, 认证参数 $K_s = y_c \cdot s_s$, 用特征函数 $\text{Cha}(x)$ 计算 $W_s = \text{Cha}(K_s), m_s = \text{REC}(W_s, K_s), K_1 = H(G_1 || G_2 || r || y_s || W_1 || T_2)$ 和会话密钥 $Sk_s = H(G_1 || G_2 || y_s || W_s || m_s)$, 向用户 C 发送参数 W_s, K_1, T_2 。

c) 用户 C 收到 W_s, K_1, T_2 后, 若 $T_m - T_2 > \Delta T$ 或者 $K_1 \neq H(G_1 || G_2 || r || y_s || W_1 || T_2)$, 则拒绝, 否则, 计算 $K_c = y_s \cdot \alpha, m_c = \text{REC}(W_s, K_c)$ 和会话密钥 $Sk_c = H(G_1 || G_2 || y_s || W_s || m_c)$ 。

2.4 口令更新阶段

在公开信道上, 用户如果长期使用固定不变的口令, 就有

泄露的风险, 文献[5~7]中并没有给出口令更新的机制, 文献[14]给出了一种口令更新机制, 但是需要 NURU 算法加解密, 根据文献[16]中描述的基于传统难题的口令更新机制, 本方案给出一种新的口令更新机制。即在用户端和服务器端分别用新的口令替换旧的口令和与口令相关的 $H(pw)$ 。本协议在验证用户成功登录后进行口令更新操作, 口令更新阶段如图3所示。

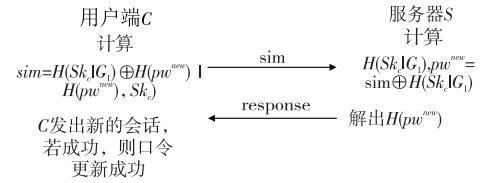


图3 口令更新阶段
Fig.3 Password update phase

a) 设用户的新口令为 pw^{new} , 在验证旧口令 pw 和 ID_c 正确后, 更新 $G_u^{new} = H(ID_c || pw^{new})$, 计算 $H(Sk_c || G_1) \oplus H(pw^{new})$, $H(H(pw^{new}), Sk_c)$ 和 $sim = H(Sk_c || G_1) \oplus H(pw^{new}) | H(H(pw^{new}), Sk_c)$, 向服务器 S 发送 sim 。

b) 服务器 S 收到 sim 后先利用 $Sk_s = Sk_c$ 计算 $H(Sk_s || G_1)$, 然后解出 $H(pw^{new}) = sim \oplus H(Sk_s || G_1)$, 最后计算 $H(Sk_s, H(pw^{new}))$, 若 $H(Sk_s, H(pw^{new}))$ 等于接收到的 $H(Sk_c, H(pw^{new}))$, 则更新 $H(pw) = H(pw^{new})$, 然后向用户 C 返回一个信号 $response$ 。

c) 用户 C 收到 $response$ 后发起一个新的会话, 如果成功则口令更新成功。

2.5 正确性证明

本协议的正确性取决于参与双方协商出的会话密钥是否相等, 即判定 m_c 是否等于 m_s , 而 $m_c = \text{REC}(W_s, K_c), m_s = \text{REC}(W_s, K_s)$, 因此正确性实际依赖于 K_c 和 K_s 的误差是否小于 $q/8$ 。如果在误差允许的范围内, 则本协议是正确的。

证明 因为 $K_c = y_s \cdot \alpha, K_s = y_c \cdot s_s, K_c - K_s = 2(\alpha e - s_s e_1)$, 根据引理1, 2 有式(11)成立。

$$|\alpha e - s_s e_1| \leq |\alpha e| + |s_s e_1| \leq \sqrt{n} \|\alpha\| \cdot \|e\| + \sqrt{n} \|s_s\| \cdot \|e_1\| < \sqrt{n} \cdot \beta \sqrt{n} \cdot \beta \sqrt{n} + \sqrt{n} \cdot \beta \sqrt{n} \cdot \beta \sqrt{n} < 2\beta^2 n^{3/2} \quad (11)$$

根据引理2, 3 和误差协调, $\beta = \omega \cdot \sqrt{\log n}$ 且 n 远小于 q , 有

$$|\alpha e - s_s e_1| < 2\beta^2 n^{3/2} < q/8 \quad (12)$$

所以在 DING 式误差允许的范围内得出 $m_s = \text{REC}(W_s, K_s) = \text{REC}(W_s, K_c) = m_c$, 得出会话密钥相等, 即 $sk_s = sk_c$ 。

证毕。

3 安全分析

3.1 形式化证明

根据文献[4]基于随机预言的安全证明和文献[13]基于 BPR 模型的安全证明的启发, 本节采用了 PWE 假设简化证明, 若敌手 A 的最佳攻击方式为在线字典攻击, 且敌手优势 $\text{ADV}_A^P(\lambda)$ 满足定理1, 则本协议是安全的。

定理1 设口令服从 CDF-Zipf 模型, PPT 敌手 A 最多进行 $N(\lambda)$ 次在线攻击, 两方 PAKA 协议为 P , 当敌手 A 优势 $\text{ADV}_A^P(\lambda)$ 是

$$\text{ADV}_A^P(\lambda) \leq C^1 N^{S^1}(\lambda) + O(q_{se} \text{ADV}_A^{\text{pwe}}(\lambda) + \text{ADV}_A^{\text{pwe}}(\lambda)) + \text{negl}(\lambda) \quad (13)$$

其中: $C^1 = 0.062\ 239$ 和 $S^1 = 0.155\ 478$ 为 CDF-Zipf 分布拟合参数^[9], q_{se} 表示敌手 A 执行 send 预言查询。

证明 本文通过一些实验 PO, P1, ..., P6 来模拟任意 PPT 敌手 A 的攻击。具体证明是通过确定相邻的两个实验间的优

势差的值是确定或可忽略的,在最后一个实验 P6 中,把敌手优势归约为了一个在线字典攻击,确定敌手的最大优势,进而确定在 P0 中的优势上限,进行直观的安全分析。

P0 本实验模拟:在实际环境下,敌手 A 攻击所提协议。

P1 本实验模拟:如果用户 C 的 μ 值或是服务器 S 的 y_s 值与之前协议中的发生重复,则 P1 停止,否则继续实验,对于任意 PPT 敌手 A 有式(14)。

$$|\text{ADV}_A^{P0}(\lambda) - \text{ADV}_A^{P1}(\lambda)| \leq \text{negl}(\lambda) \quad (14)$$

PPT 敌手 A 可以执行 send、execute 和随机预言查询,分别用 q_{se}, q_{ex}, q_{ro} 表示。已经在 send、execute、oracle 查询发送过的 μ 或 y_s 值的概率为 $(q_{se} + q_{ex} + q_{ro})/Q$,而通过 send、execute 查询生成新的 μ 或 y_s 的个数是 $(q_{se} + q_{ex})$ 个,所以发生重复的概率为 $O((q_{se} + q_{ex} + q_{ro})(q_{se} + q_{ex}))/R_q$,这是可以忽略的。所以式(13)成立。

P2 本实验模拟:响应敌手 A 的 send、execute 查询,而不进行任何随机预言查询。之后的实验会模拟敌手执行随机预言查询,尽可能与 send、execute 查询的响应保持一致。对于任意 PPT 敌手 A 有式(15)。

$$|\text{ADV}_A^{P1}(\lambda) - \text{ADV}_A^{P2}(\lambda)| \leq \text{negl}(\lambda) \quad (15)$$

对于存在随机预言查询的安全分析中,实验 P2 的设计是标准的。P1 和 P2 是不可区分的,除非 P2 中存在随机预言查询,但是在 P2 中敌手没有执行 $H(pw)$ 查询,所以式(15)成立。

P3 本实验模拟:敌手执行 $H(\cdot)$ 查询,如果敌手执行了 $H(\cdot)$ 查询,P3 以随机输出代替之前的 execute 查询的输出。对于任意 PPT 敌手 A 有式(16)。

$$|\text{ADV}_A^{P2}(\lambda) - \text{ADV}_A^{P3}(\lambda)| \leq \text{ADV}_A^{PWE}(\lambda) \quad (16)$$

式(16)的证明使用到了 PWE 假设, A 攻击实验 P2,敌手尝试使用算法 Q 解决 PWE 假设,且作出以下改变:

a) 假设敌手持有参数 (A, z) ,在 execute 查询中,敌手获得 W_s, Q 算法设 $\mu = As_f + e_f, y_s = z + As_{ff} + e_{ff}$,其中 $(s_f, s_{ff}, e_f, e_{ff}) \leftarrow R_q$ 。

b) 敌手执行 $H(\cdot)$ 查询后,得到 $r^1 = As_h + e_h \in R_q$ 。然后算法 Q 模拟计算 $y_c^1 = (\mu \oplus r) = (As_f + e_f) \oplus (As_h + e_h)$,然后计算 $Ks^1 = y_c^1 s_s = (As_f + e_f) \oplus (As_h + e_h) s_s, F^1 = \text{REC}(W_s, Ks^1) = \text{REC}(W_s, (As_f + e_f) \oplus (As_h + e_h) s_s)$,此时敌手相当于持有了 (A, y, z) ,但要解出 F^1 相当于解决 PWE 问题。因此,有 $|\text{ADV}_A^{P2}(\lambda) - \text{ADV}_A^{P3}(\lambda)| \leq \text{ADV}_A^{PWE}(\lambda)$ 成立,其中 $\text{ADV}_A^{PWE}(\lambda)$ 表示解决 PWE 假设的敌手优势,这是可以忽略的。所以式(16)成立。

P4 本实验模拟:若在 corrupt 查询前,敌手 A 获得口令 pw ,则敌手成功,实验 P4 结束。对于任意 PPT 敌手 A 有式(17)。

$$\text{ADV}_A^{P4}(\lambda) \geq \text{ADV}_A^{P3}(\lambda) \quad (17)$$

实验 P4 比实验 P3 只增加了敌手攻击成功的概率。所以式(17)成立。

P5 本实验模拟:若敌手 A 在互为伙伴的两个实例间执行在线口令攻击,则敌手失败,实验结束。对于任意 PPT 敌手 A ,有

$$|\text{ADV}_A^{P5}(\lambda) - \text{ADV}_A^{P4}(\lambda)| \leq q_{se} \text{ADV}_A^{PWE}(\lambda) \quad (18)$$

证明 设实例 Π_c^i 和 Π_s^i 互为伙伴关系,敌手 A 在这两个实例间执行在线口令攻击,记此事件为 guesspw。显然当 guesspw 没有发生时,P5 和 P4 是不可区分的。因此根据 $\text{ADV}_A^P(\lambda) = 12\text{Pr}(\text{succ}_A^P(\lambda)) - 1$ 可得,如果有两个协议 P 和 P^1 满足式(19)的关系。

$$\text{Pr}(\text{succ}_A^P(\lambda)) - \text{Pr}(\text{succ}_A^{P^1}(\lambda)) = \varepsilon \quad (19)$$

则式(20)成立

$$\text{ADV}_A^P(\lambda) - \text{ADV}_A^{P^1}(\lambda) = 2\varepsilon \quad (20)$$

因此设 $\text{Pr}(\text{succ}_A^{P5}(\lambda)) - \text{Pr}(\text{succ}_A^{P4}(\lambda)) \leq \varepsilon$ 可得。式(20)的证明使用到了 PWE 假设, A 攻击实验 P4,随机选择一个 $\mu \in$

$\{n_{se1}, n_{se2}, n_{se3}, \dots, n_{seem}\}$ 且在敌手未执行 test 和 corrupt 查询的前提下,敌手尝试使用算法 Q 解决 PWE 假设,作出以下改变:

a) 假设敌手持有 (A, z) ,在对实例 Π_c^i 第 n 次 send (C, i, S) 查询中,令 $\mu = m$ 。

b) 在 send $(S, j, (\mu, T_1, K))$ 查询中,令 $y_s = z + As_{ff} + e_{ff}$ 。

c) 在 send $(C, i, (W_s, K_1, T_2))$ 查询中,如果实例 Π_c^i 没有伙伴,Q 输出 0 且终止攻击。

d) A 执行 $H(\cdot)$ 查询后,得到 $r^1 = As_h + e_h \in R_q$ 然后算法 Q 模拟计算 $y_c^1 = (\mu \oplus r) = m \oplus (As_h + e_h)$,然后计算 $Ks^1 = y_c^1 s_s = m \oplus (As_h + e_h) s_s, F^1 = \text{REC}(W_s, Ks^1) = \text{REC}(W_s, m \oplus (As_h + e_h) s_s)$,此时敌手相当于持有了 (A, y, z) ,但要解出 F^1 相当于解决 PWE 问题。因此,有 $\text{ADV}_A^{P5}(\lambda) - \text{ADV}_A^{P4}(\lambda) \leq 2q_{se} \text{ADV}_A^{PWE}(\lambda)$,这是可以忽略的。所以式(20)成立。

P6 本实验模拟:test 查询获取会话密钥 sk ,对于任意 PPT 敌手 A 有式(21)。

$$\text{ADV}_A^{P5}(\lambda) = \text{ADV}_A^{P6}(\lambda) \quad (21)$$

P6 与 P5 是不可区分的,在实验 P6 中,敌手有两种方式攻击成功:(a) 通过在线字典攻击成功,记为事件 correctpw,而 correctpw 的概率与 CDF-Zipf 模型^[9]相关;(b) 当在线字典攻击失败后,敌手只能执行 test 查询,对于新鲜的 sk ,敌手攻击成功的概率为 1/2。所以有式(22)。

$$\begin{aligned} \text{Pr}(\text{succ}_A^{P6}(\lambda)) &\leq \text{Pr}(b = b_1) + \text{Pr}(b \neq b_1) \text{Pr}(\text{correctpw}) \leq \\ &1/2 C^1 N^{S^1}(\lambda) + 1/2 = 1/2(1 + C^1 N^{S^1}(\lambda)) \end{aligned} \quad (22)$$

进一步有 $\text{ADV}_A^{P6}(\lambda) = 2\text{Pr}(\text{succ}_A^{P6}(\lambda)) - 1 \leq C^1 N^{S^1}$ 。由实验 P1 ~ P6 可得

$$\text{ADV}_A^P(\lambda) \leq C^1 N^{S^1}(\lambda) + O(q_{se} \text{ADV}_A^{PWE}(\lambda) + \text{ADV}_A^{PWE}(\lambda)) + \text{negl}(\lambda) \quad (23)$$

综上,定理 1 成立。证毕。

实验分析:文献[7,14]在随机预言模型下进行了安全证明,其假设所用的哈希函数是不可碰撞的,但是在实际中存在一定的安全风险,一旦 PPT 敌手使用可替代的哈希函数,碰撞获得与文献[7,14]相同的哈希值,则会话密钥 sk 面临泄露的风险,而所提 PAKA 协议在改进的 BPR 模型下进行了严格的形式化安全证明。其中实验 P1 模拟实际环境下协议所面临的各种安全挑战;实验 P2 模拟了所用参数 μ 或者是 y_s 发生重复的情况;实验 P3 ~ P5 模拟了 PPT 敌手使用哈希碰撞获得 μ ,进而计算出 y_c ,这就相当于敌手获取了 PWE 问题的相关参数,但是根据 PWE 问题的难解性,敌手不能对所提 PAKA 协议会话密钥 sk 的安全造成威胁;实验 P6 将敌手的攻击能力最大化。综上,实验 P1 ~ P6 结合了实际环境下敌手攻击的各种可能的方式,如离线字典攻击、在线字典攻击、中间人攻击等,且可以有效地证明所提方案是后量子安全的。与文献[7,14]相比,通信过程传输的消息相对较少,执行效率更高,安全性更高。

3.2 安全特性分析

本节对所提 PAKA 的安全特性进行简要分析。

a) 对于任意 PPT 敌手 A ,所提协议具有匿名性。在注册阶段,用户 ID 就通过 $G_u = H(ID_c | pw)$ 隐藏,敌手就算得到 G_u ,由于没有口令 pw ,所以无法获取用户的 ID。本协议实现匿名认证,更能保护用户隐私。

b) 对于任意 PPT 敌手 A ,所提协议具有可抗离线字典攻击性。假设敌手获得了用户智能设备存储的信息 G_2 ,设敌手进行离线字典攻击所猜测的口令为 pw_i ,要想验证所猜测的口令 pw_i 是否正确,敌手需要构造 G_u ,但是缺少用户的 ID。因此,所提协议可抗离线字典攻击。

c) 对于任意 PPT 敌手 A ,所提协议具有可抗重放攻击性。当敌手从上一个会话获得所需身份验证消息并作为一个合法用户在

当前会话中使用该消息时,就会出现重放攻击。但是在本协议中,每一次用户 C 和 S 分别使用不同的噪声 e, e_1 和时间戳。用户在验证后会捕获重放攻击,因此,本协议可抗重放攻击。

d) 对于任意 PPT 敌手 A , 所提协议具有口令更新安全性, 传输的消息使用 $sim = H(Sk_c | G_1) \oplus H(pw^{new} | H(pw^{new}), Sk_c)$, 敌手没有会话密钥, 不能解出 pw^{new} , 敌手若进行离线字典攻击, 但是无法验证新口令 pw^{new} 的正确性, 口令更新阶段也可抗离线字典攻击。因此, 所提协议具有口令更新安全性。

3.3 性能分析

本节分析了有关基于 RLWE 的 PAKA 协议的计算成本, 并讨论了本方案与现有相关协议的差异, 根据文献 [9, 10, 15], 本文选用哈希函数 SHA-3, 输出为 512 bit, 长度为 32 bit 的时间戳。长度为 32 bit 的口令 pw , 各类 ID 长度为 32 bit。 n 的长度为 1 024 bit, 格上离散高斯分布的标准差 $\log \beta = 17.1$, R_q 长度为 4 096 bit。下面对有关的各种加密操作以及在用户和服务器端所花费的时间进行描述。本文中定义 T_g 表示从离散高斯分布抽样, T_{sm} 是环 R_q 上的离散标量乘法操作, T_{pm} 表示环 R_q 上离散乘法, T_{pma} 表示环 R_q 上先乘后加操作, T_{Cha} 是特征函数, T_h 表示散列操作, 相关操作的时间成本列于表 2。表 2 的数据来源于 Lattice-crypto 数据库^[17]。

表 2 各种操作耗时

Tab. 2 Time taken by various operations

操作标识	客户端 $C/\mu s$	服务器 $S/\mu s$	操作标识	客户端 $C/\mu s$	服务器 $S/\mu s$
T_g	0.561 483	0.073 503	T_{Cha}	0.035 515	0.000 689
T_{sm}	0.006 655	0.000 298	T_h	0.180 964	0.014 09
T_{pm}	0.001 305 2	0.000 307	T_{fe}	17 909	2 578
T_{pma}	0.029 505	0.002 549			

实现环境: 服务器端编程语言为 C 和 C++。戴尔电脑配置: 操作系统 Windows 10, 处理器为英特尔第七代 (3.4 GHz), 内存 8 GB, 用户端使用三星移动 4.3 操作系统, 处理器 Exynos-4412 (1.4 GHz), 内存 1 GB^[6, 15], 由于 REC 函数只包含异或操作, 用时较短, 可以忽略。

在所提协议中用户 C 首先使用 ID_c 和口令 pw 登录其智能设备, 然后智能设备执行一个 T_h 操作进行验证, 在成功登录后, 智能设备执行 2 次 T_g 操作, 然后执行一次环上的 T_{pma} 操作, 计算 K_c 执行了一次 T_{sm} , 根据图 2 可得, 最后用户 C 的计算消耗为 $5T_h + 2T_g + T_{sm} + T_{pm} + T_{pma} \approx 2.065\ 251\ \mu s$ 。同理, 服务器 S 的计算消耗为 $3T_h + 2T_g + T_{sm} + T_{pm} + T_{pma} + T_{Cha} \approx 0.193\ 119\ \mu s$ 。总耗时 $2.065\ 251 + 0.193\ 119 = 2.258\ 37\ \mu s$ 。所提协议与相关方案的计算开销如表 3 所示。

表 3 计算开销对比

Tab. 3 Calculation cost comparison

方案	客户端 C	服务器 S	总计/ μs
文献[15]	$T_{fe} + 7T_h + 2T_g + T_{sm} + 2T_{pm} + T_{pma} + T_{Cha}$	$5T_h + 2T_g + T_{sm} + 2T_{pm} + T_{pma} + T_{Cha}$	179 11.685 606
文献[6]	$6T_h + 2T_g + T_{sm} + 2T_{pm} + T_{pma} + T_{Cha}$	$5T_h + 2T_g + 2T_{sm} + T_{pm} + T_{pma} + T_{Cha}$	2.504 632
文献[4]	$4T_h + 2T_g + 2T_{sm} + T_{pm} + T_{pma}$	$5T_h + 2T_g + 2T_{sm} + T_{pm} + T_{pma} + T_{Cha}$	2.112 539
文献[5]	$4T_h + 2T_g + 2T_{sm} + T_{pm} + T_{pma}$	$5T_h + 2T_g + 2T_{sm} + T_{pm} + T_{pma} + T_{Cha}$	2.112 539
文献[7]	$6T_h + 2T_g + T_{sm} + 2T_{pm} + T_{pma} + T_{Cha}$	$4T_h + 2T_g + T_{sm} + 2T_{pm} + T_{pma} + T_{Cha}$	2.490 551
本文方案	$5T_h + 2T_g + T_{sm} + T_{pm} + T_{pma}$	$3T_h + 2T_g + T_{sm} + T_{pm} + T_{pma} + T_{Cha}$	2.258 37

根据文献[7], 在认证阶段所提协议的用户 C 向 S 发送 $\langle X, G_w, G_3, C_u \rangle$ 的通信开销为 $4\ 096 + 512 + 1 + 512 = 5\ 121\ \text{bit}$, S 向用户 C 发送 $\langle G_x, X_s, C_s \rangle$ 的通信开销为 $4\ 096 + 1 + 512 = 4\ 609\ \text{bit}$, 总消耗为 $5\ 121 + 4\ 609 = 9\ 730\ \text{bit}$ 。类似地, 本方案用户 C 向 S 发送 $\langle \mu,$

$T_1, K \rangle$ 的通信开销为 $4\ 096 + 32 + 512 = 4\ 613\ \text{bit}$, S 向用户 C 发送 $\langle W_s, K_1, T_2 \rangle$ 的通信开销为 $1 + 512 + 32 = 545\ \text{bit}$, 总消耗为 $4\ 613 + 545 = 5\ 158\ \text{bit}$ 。通信开销对比如表 4 所示。

表 4 通信开销对比

Tab. 4 Comparison of communication overhead

方案	消息/bit		总计/bit
	C 发送	S 发送	
文献[15]	5 118	4 606	9 724
文献[6]	5 121	4 609	9 730
文献[4]	4 192	4 256	8 448
文献[5]	4 352	4 161	8 513
文献[7]	5 121	4 609	9 730
本文方案	4 613	545	5 158

本文方案与相关方案的安全性和其他性能的对比如表 5 所示。

表 5 安全性和其他性能对比

Tab. 5 Security and other performance comparisons

方案	协议类型	安全假设	公钥尺寸/bit	抗字典攻击	通信轮数
文献[15]	RO	RLWE	4 094	是	3
文献[6]	RO	RLWE	4 096	是	3
文献[5]	RO	RLWE	4 096	是	3
文献[7]	RO	RLWE	4 096	是	2
本文方案	BPR	RLWE	4 096	是	2

性能对比结果表明, 所提 PAKA 协议在公钥尺寸相同的情况下, 安全性能更高, 与文献[5~7]相比, 所提协议通过减少环上的运算次数, 降低了通信轮数和计算开销。

4 结束语

本文基于 RLWE 问题的难解性, 提出了一种格上匿名两方 PAKA 协议, 所提协议可抗目前已知的量子计算攻击和服务器泄露以及离线字典攻击。在认证阶段服务器和用户之间仅需要交互一次信息, 无须使用签名、验签、同态加密等开销较大的密码源语, 且在改进的 BPR 模型下进行了严格的安全性证明。与相关方案相比, 其提高了执行效率。下一步考虑使用 LWE 困难问题设计更为安全高效的后量子匿名口令认证协议。

参考文献:

- [1] Islam M Z, Ali R, Haider A, et al. A reinforcement learning-based personalized adaptability knowledge extraction strategy for adaptive learning systems[J]. IEEE Access, 2021, 9(1): 155123-155137.
- [2] Zhang Yuan, Xu Chunxiang, Li Hongwei, et al. Efficient password-based threshold single-sign-on authentication for mobile users against perpetual leakage[J]. IEEE Trans on Mobile Computing, 2021, 20(6): 2297-2312.
- [3] Ding Jintai, Xie Xiang, Lin Xiaodong. A simple provably secure key exchange scheme based on the learning with errors problem [EB/OL]. (2012) [2022-07-03]. https://ia.cr/2012/688.
- [4] Ding Jintai, Alsayigh S, Lancrenon J, et al. Provably secure password authenticated key exchange based on RLWE for the post-quantum world [C]//Proc of Cryptographers' Track at RSA Conference. Cham: Springer, 2017: 183-204.
- [5] Gao Xinwei, Ding Jintai, Li Lin, et al. Efficient implementation of password-based authenticated key exchange from RLWE and post-quantum TLS [EB/OL]. (2017-12-18) [2022-07-03]. https://ia.cr/2017/1192.
- [6] Feng Qi, He Debiao, Zeadally S, et al. Ideal lattice-based anonymous authentication protocol for mobile devices[J]. IEEE Systems Journal, 2019, 13(3): 2775-2785.
- [7] Rana S, Mishra D. Lattice-based key exchange protocol under ring-LWE problem for IoT-enabled smart devices[J]. Sādhan, 2021, 46(84): 83-94.
- [8] Bellare M, Pointcheval D, Rogaway P. Authenticated key exchange secure against dictionary attacks [C]//Proc of EUROCRYPT. Berlin: Springer, 2000: 139-155.

- signcryption for network coding[J]. *Knowledge-Based Systems*, 2021, 235:107655.
- [10] Chaum D. Blind signatures for untraceable payments[M]// Chaum D, Rivest R L, Sherman A T. *Advances in Cryptology*. Boston, MA: Springer, 1983:199-203.
- [11] Chen Siyuan, Zeng Peng, Raymond K K. A new code-based blind signature scheme[J]. *The Computer Journal*, 2022, 65(7):1776-1786.
- [12] Cai Zhengying, Liu Shi, Han Zhangyi, *et al.* A quantum blind multi-signature method for the industrial blockchain[J]. *Entropy*, 2021, 23(11):article ID 1520.
- [13] Chen Jingjing, You Fucheng. A quantum multi-agent blind signature scheme with unordered signatures[J]. *Journal of Physics: Conference Series*, 2021, 1883(1):article ID 012076.
- [14] Jiang Yuhong, Deng Lunzhi, Ning Bingqin. Identity-based partially blind signature scheme: cryptanalysis and construction[J]. *IEEE Access*, 2021, 9:78017-78024.
- [15] Zhang Minghui, Xie Jiahui. High fidelity quantum blind dual-signature protocols[J]. *Modern Physics Letters B*, 2022, 36(13):article ID 2250064.
- [16] Sanjeet K N, Sujata M, Banshidhar M. Certificateless blind signature using ECC[J]. *Journal of Information Processing Systems*, 2017, 4(13):970-986.
- [17] 曾丽, 李旭东. 基于椭圆曲线的强无证书盲签名方案[J]. *网络空间安全*, 2018, 9(5):41-44. (Zeng Li, Li Xudong. A strong certificate free blind signature scheme based on elliptic curve[J]. *Cyber-space Security*, 2018, 9(5):41-44.)
- [18] Liao Xiaoping. Certificate-free blind parameter signature scheme[J]. *Modern Information Technology*, 2019, 3(3):158-159.
- [19] 唐卫中, 张大伟, 佟晖. 基于 SM2 的无证书盲签名方案[J]. *计算机应用研究*, 2022, 39(2):552-556. (Tang Weizhong, Zhang Dawei, Tong Hui. Certificateless blind signature scheme based on SM2[J]. *Application Research of Computers*, 2022, 39(2):552-556.)
- [20] Yu Huifang, Wang Zhicang. Certificateless blind signcryption with low complexity[J]. *IEEE Access*, 2019, 7:115181-115191.
- [21] 宋明明, 张彰, 谢文坚. 没有对运算的无证书盲签名方案[J]. *广西民族大学学报:自然科学版*, 2011, 17(1):64-67. (Song Ming-ming, Zhang Zhang, Xie Wenjian. Certificateless blind signcryption scheme without pairing[J]. *Journal of Guangxi University for Nationalities*, 2011, 17(1):64-67.)
- [22] 王鑫, 刘景美, 王新梅. 多变量签名模型的改进[J]. *北京邮电大学学报*, 2009, 32(5):124-127. (Wang Xin, Liu Jingmei, Wang Xinmei. Improvement on multivariate signature scheme model[J]. *Journal of Beijing University of Posts and Telecommunications*, 2009, 32(5):124-127.)
- [23] 李慧贤, 王凌云, 庞辽军. 一种混合多变量签名方案[J]. *软件学报*, 2018, 29(2):456-472. (Li Huixian, Wang Lingyun, Pang Liao-jun. Mixed multivariate signature scheme[J]. *Journal of Software*, 2018, 29(2):456-472.)
- [24] 郭秋玲, 向宏, 蔡斌, 等. 基于多变量公钥密码体制的门限环签名方案[J]. *密码学报*, 2018, 5(2):140-150. (Guo Qiuling, Xiang Hong, Cai Bin, *et al.* Threshold ring signature scheme based on multivariate public key cryptosystems[J]. *Journal of Cryptologic Research*, 2018, 5(2):140-150.)
- [25] 俞惠芳, 付帅凤. 抗量子计算的多变量盲签名方案[J]. *软件学报*, 2021, 32(9):2935-2944. (Yu Huifang, Fu Shuaifeng. Post-quantum blind signature scheme based on multivariate cryptosystems[J]. *Journal of Software*, 2021, 32(9):2935-2944.)
- [26] 俞惠芳, 张帅. 多变量体制下的代理签名方案[J]. *计算机应用研究*, 2022, 39(7):2167-2171. (Yu Huifang, Zhang Shuai. Proxy signcryption scheme based on multivariate cryptosystem[J]. *Application Research of Computers*, 2022, 39(7):2167-2171.)
- [27] Yu Huifang, Zhang Shuai, Liu Yue. Certificateless multivariate ring signcryption scheme[J]. *Journal of Information Security and Application*, 2022, 68(8):103220.
- [28] Johnson D S. The NP-completeness column: an ongoing guide[J]. *Journal of Algorithms*, 1984, 5(3):433-447.
- [29] Patarin J. Hidden fields equations (HFE) and isomorphisms of polynomials (IP): two new families of asymmetric algorithms[M]//Maurer U. *Advances in Cryptology*. Berlin: Springer, 1996:33-48.
- (上接第1213页)
- [9] Wang Ding, Cheng Haibo, Wang Ping, *et al.* Zipf's law in passwords[J]. *IEEE Trans on Information Forensics and Security*, 2017, 12(11):2776-2791.
- [10] Ajtai M. Generating hard instances of lattice problems[C]//Proc of the 28th Annual ACM Symposium on Theory of Computing. New York: ACM Press, 1996:99-108
- [11] Micciancio D. Generalized compact knapsacks cyclic lattices and efficient one-way functions[J]. *Computational Complexity*, 2007, 16(4):365-411.
- [12] 舒琴, 王圣宝, 胡斌, 等. 格上两方口令认证密钥交换协议研究综述[J]. *杭州师范大学学报:自然科学版*, 2021, 20(5):463-470. (Shu Qin, Wang Shengbao, Hu Bin, *et al.* A survey of two party password authentication key exchange protocol on lattice[J]. *Journal of Hangzhou Normal University: Natural Science Edition*, 2021, 20(5):463-470.)
- [13] Ren Peixin, Gu Xiaozhuo. Practical post-quantum password-authenticated key exchange based-on module-lattice[C]//Proc of International Conference on Information Security and Cryptology. Cham: Springer, 2022:137-156.
- [14] 李子臣, 谢婷, 张卷美. 基于 RLWE 问题的后量子口令认证密钥交换协议[J]. *电子学报*, 2021, 49(2):260-267. (Li Zichen, Xie Ting, Zhang Juanmei. Post-quantum password authenticated key exchange protocol based on RLWE problem[J]. *Acta Electronic Sinica*, 2021, 49(2):260-267.)
- [15] Dharminder D, Chandran K P. LWESM: learning with error based secure communication in mobile devices using fuzzy extractor[J]. *Journal of Ambient Intelligence and Humanized Computing*, 2020, 11(1):4089-4100.
- [16] 罗璇, 曹天杰. 改进的抵抗离线字典攻击的口令更新协议[J]. *计算机工程与应用*, 2009, 45(25):118-120. (Luo Xuan, Cao Tianjie. Improved password update protocol against offline dictionary attack[J]. *Computer Engineering and Applications*, 2009, 45(25):118-120.)
- [17] Aguilar-Melchor C, Barrier J, Guelton S, *et al.* NTLIB: NTT-based fast lattice library[C]//Proc of Cryptographers' Track at the RSA Conference. Cham: Springer, 2016:341-356.
- [18] Dabra V, Bala A, Kumari S. LBA-PAKA: lattice-based anonymous password authenticated key exchange for mobile devices[J]. *IEEE Systems Journal*, 2021, 15(1):5067-5077.
- [19] Yao Hailong, Wang Caifen, Fu Xingbing, *et al.* A privacy-preserving RLWE-based remote biometric authentication scheme for single and multi-server environments[J]. *IEEE Access*, 2019, 7:109597-109611.
- [20] 廉欢欢, 侯慧莹, 赵运磊. 后量子基于验证元的三方口令认证密钥交换协议[J]. *通信学报*, 2022, 43(4):95-106. (Lian Huanhuan, Hou Huiying, Zhao Yunlei. Postquantum three-party password authentication key exchange protocol based on verification element[J]. *Journal on Communications*, 2022, 43(4):95-106.)
- [21] 尹安琪, 郭渊博, 汪定, 等. 可证明安全的抗量子两服务器口令认证密钥交换协议[J]. *通信学报*, 2022, 43(3):14-29. (Yin Anqi, Guo Yuanbo, Wang Ding, *et al.* Demonstrably secure quantum-proof two-server password authentication key exchange protocol[J]. *Journal on Communications*, 2022, 43(3):14-29.)